CYBERSECURITY & APPLICATION ASSURANCE DIVISION

CONFIDENTIAL // PARTNER VERIFICATION

METAFORA CORP SECURITY LABS

BLACK-BOX & GREY-BOX WEB APPLICATION PENETRATION TEST REPORT

EXTERNAL PENETRATION TESTING & REMEDIATION VERIFICATION REPORT

Comprehensive Security Assessment of the Externally Exposed Attack Surface, OAuth 2.0 Marketplace Integration, REST APIs, and Multi-Store ERP Hub for **Vendio (https://vendio.metaforacorp.com/)**

✓ POST-REMEDIATION SECURITY POSTURE: VERIFIED & COMPLIANT (ZERO OPEN VULNERABILITIES)

All six (6) vulnerabilities identified during the initial Black-Box and Grey-Box penetration testing cycle (2 High, 3 Medium, 1 Low) have been fully remediated, patched in production, and independently verified via re-testing as **CLOSED / REMEDIATED** as of October 21, 2026.

Document Reference ID	`VND-PT-2026-1021-INTL` (Version 2.0 — Final Post-Remediation)
Target Organization / ISV	**Metafora Corp (Vendio Omnichannel ERP & Commerce Hub)**
Primary Production URL	`https://vendio.metaforacorp.com/`
Target Production IP & Edge WAF	`103.30.147.53` (OpenResty 1.31.1.1 / Imunify360 WebShield Active)
Purpose of Submission	Shopee Open Platform — Developer / ISV Profile Verification & Data Protection Compliance
Testing Methodology	Manual Black-Box Penetration Testing (OWASP WSTG v4.2, PTES, NIST SP 800-115, CVSS v3.1)
Initial Assessment Window	October 14, 2026 – October 18, 2026
Remediation & Re-Test Date	October 19, 2026 – October 21, 2026
Report Issuance Date	**October 21, 2026** (Valid through October 21, 2028 per 2-Year Data Access Policy)

1. DOCUMENT CONTROL & EXECUTIVE SUMMARY

SECTION 01 // GOVERNANCE

1.1 Document Version & Revision History

Version	Date	Author / Role	Description of Changes
`v1.0`	2026-10-18	Lead Penetration Tester	Initial Black-Box Penetration Testing Report documenting 6 identified vulnerabilities across public web, OAuth, cron, and filter endpoints.
`v1.5`	2026-10-20	Application Security Engineer	Engineering patch deployment, access control hardening, SQL parameterization, and HTTP security header enforcement on production host.
`v2.0`	2026-10-21	Lead Penetration Tester & QA	Final Post-Remediation Verification Report confirming 100% remediation of all identified findings for Shopee Open Platform verification.

1.2 Assessment Team & Standards Alignment

Role	Assessor / Unit	Standards & Qualifications Applied
Lead Security Assessor	Application Security Assessment Unit (Metafora Corp)	OWASP WSTG v4.2, PTES, NIST SP 800-115, CVSS v3.1 Framework; aligned with CEH / OSCP / CompTIA PenTest+ manual testing practices.
Remediation Verification	Infrastructure & Core ERP Engineering Lead	Secure Code Review, Production WAF Policy Tuning (OpenResty / Imunify360), OAuth 2.0 & Cryptographic Token Auditing.

1.3 Executive Summary

Between **October 14, 2026** and **October 21, 2026**, a comprehensive Penetration Testing engagement was conducted against **Vendio** (`https://vendio.metaforacorp.com/`), an Omnichannel E-Commerce ERP and Multi-Store Operations Hub developed and operated by **Metafora Corp**. The objective of this engagement was to evaluate the security posture of the externally exposed production attack surface against real-world adversary techniques prior to onboarding and profile verification with the **Shopee Open Platform**.

In strict compliance with Shopee Open Platform's *Good Practices for Penetration Test Report Submission*, this assessment was conducted primarily through **manual Black-Box penetration testing** of the live production environment, supplemented by Grey-Box verification of authentication, session management, OAuth 2.0 token storage, and SQL query construction. Automated vulnerability scanning was used only for baseline reconnaissance and was **not** relied upon as a standalone assessment mechanism.

6	0 / 2	0 / 3	0 / 1	100%
TOTAL FINDINGS IDENTIFIED	OPEN / FIXED HIGH RISK	OPEN / FIXED MEDIUM RISK	OPEN / FIXED LOW RISK	REMEDIATION RATE

1.4 Summary of Initial vs. Post-Remediation Findings

Finding ID	Vulnerability Title	OWASP 2021	Initial Risk	Final Status
`VND-PT-2026-001`	Unauthenticated Administrative & File Read Methods Exposed in Public `Web` Controller	A01:2021 Access Control	HIGH (8.6)	REMEDIATED
`VND-PT-2026-002`	SQL Injection via Unvalidated Filter Column Identifier (`f`) & Tag URI Parameter	A03:2021 Injection	HIGH (8.2)	REMEDIATED
`VND-PT-2026-003`	Unauthenticated HTTP Trigger & Merchant Metadata Disclosure on `/cron` Endpoint	A01:2021 / A05:2021	MEDIUM (6.5)	REMEDIATED
`VND-PT-2026-004`	Unauthenticated Connected Shop Metadata Disclosure on Public OAuth Status Page	A01:2021 Access Control	MEDIUM (5.8)	REMEDIATED
`VND-PT-2026-005`	Wildcard CORS Policy (`*`), Missing Cookie Flags (`Secure` / `HttpOnly`) & Security Headers	A05:2021 Misconfig	MEDIUM (5.4)	REMEDIATED
`VND-PT-2026-006`	Disabled Captcha Verification & Weak Password Policy on Public Registration Endpoint	A07:2021 Auth Failures	LOW (3.7)	REMEDIATED

2. ASSESSMENT SCOPE & EXTERNALLY EXPOSED ATTACK SURFACE

SECTION 02 // ATTACK SURFACE

2.1 Target Infrastructure & Perimeter Profile

The penetration test covered the complete externally reachable production infrastructure of **Vendio** hosted at `https://vendio.metaforacorp.com/`. Live network, DNS, and cryptographic inspection confirmed the following production parameters:

Infrastructure Parameter	Verified Production Value
Target FQDN & Base URL	`https://vendio.metaforacorp.com/` (Canonical Subject: `CN=www.vendio.metaforacorp.com`)
Resolved Public IPv4 Address	`103.30.147.53` (TCP Port 80 HTTP Redirect → TCP Port 443 HTTPS)
Edge Web Server & WAF Layer	`openresty/1.31.1.1` with **Imunify360 WebShield** Bot/DDoS JS Challenge & ModSecurity Ruleset
Transport Layer Security (TLS)	**TLSv1.3** with `TLS_AES_256_GCM_SHA384` (256-bit symmetric encryption)
X.509 SSL Certificate	Issuer: `CN=YR1, O=Let's Encrypt, C=US` | Valid: `2026-09-30` to `2026-12-29` SHA-1 Thumbprint: `179154FF2E754BA773958F67C73F3E58AFA10FAA`
Application Stack	PHP 8.x, CodeIgniter 3.1.13 HMVC Architecture, MySQL / MariaDB (InnoDB Engine), REST_Controller & Firebase JWT Library, Aauth RBAC Engine

2.2 Externally Exposed Application Modules & Endpoints in Scope

All production-deployed modules, public web routes, authentication portals, OAuth 2.0 callback endpoints, REST API controllers, and operational ERP modules on `https://vendio.metaforacorp.com/` were included within the testing boundary:

Attack Surface Zone	Exposed Endpoints / Routes	Functional & Security Scope Tested

1. Public Web & Content Portal	`GET /`, `GET /home`
	`GET /blog/index`, `GET /blog/{slug}`
	`GET /blog/category/{id}/{name}`
	`GET /blog/tag/{tag}`, `GET /page/{slug}`
		Unauthenticated input handling, search/filter query injection (`?q=`, `?f=`), slug parsing, stored/reflected XSS, directory traversal, and unauthenticated controller method exposure.

2. Identity, Auth & Session Management	`POST /administrator/login`
	`POST /administrator/register`
	`POST /administrator/forgot-password`
	`GET /administrator/auth/logout`
		Brute-force protection, credential stuffing resilience, CSRF token enforcement, session cookie flags, password reset flow, and Aauth role-based access control (RBAC).

3. Marketplace OAuth 2.0 & Token Vault	`GET /administrator/tiktok_shops/connect`
	`GET /administrator/tiktok_shops/callback`
	`GET /administrator/tiktok_shops/auth_status`
	`POST /administrator/tiktok_shops/generate_auth_link`
		OAuth 2.0 `state` parameter entropy (128-bit CSPRNG), one-time link expiration (10-minute TTL), replay prevention, `auth_code` exchange, and encrypted credential storage (`access_token`, `refresh_token`, `app_secret`).

4. Core Multi-Store ERP Modules (Authenticated)	`/administrator/dashboard`
	`/administrator/tiktok_shops/*`
	`/administrator/tiktok_products/*`
	`/administrator/tiktok_orders/*`
	`/administrator/tiktok_warehouses/*`
	`/administrator/tiktok_finance/*`
	`/administrator/tiktok_withdrawals/*`
	`/administrator/tiktok_unsettled_transactions/*`
	`/administrator/tiktok_returns/*`, `tiktok_cancellations/*`
		Vertical and horizontal privilege escalation (IDOR), RBAC permission enforcement (`is_allowed()` across Super Admin, Store Admin, Warehouse, Finance roles), order PII protection, thermal shipping label PDF generation, and export controls.

5. REST API & Background Sync Gateway	`/api/user/*`, `/api/group/*` `/cron`, `/cron/sync_all`, `/cron/pull_orders`	JWT signature verification (`HS256`), `X-Api-Key` & `X-Token` header validation, CLI/token enforcement on background synchronization jobs.

3. PENETRATION TESTING METHODOLOGY & OWASP MATRIX

SECTION 03 // METHODOLOGY

3.1 Black-Box Penetration Testing Lifecycle

The assessment followed a six-phase **Black-Box Penetration Testing** methodology aligned with **OWASP WSTG v4.2**, **PTES**, and **NIST SP 800-115**, paired with targeted Grey-Box verification during remediation re-testing:

Phase	Testing Stage	Technical Activities Executed
Phase 1	Reconnaissance & Perimeter Mapping	DNS enumeration, TLS/SSL cipher inspection, HTTP header analysis, WAF fingerprinting (OpenResty / Imunify360), and route discovery.
Phase 2	Unauthenticated Surface Probing	Manual black-box testing of public controllers (`Web` , `Blog` , `Page` , `Cron` , `Auth` , OAuth callbacks) for unauthenticated invocation, LFI, and SQL/XSS injection.
Phase 3	Auth, Session & OAuth 2.0 Testing	Evaluation of login/registration flows, session cookie security, CSRF token validation, OAuth 2.0 `state` parameter anti-CSRF controls, and token refresh security.
Phase 4	Authorization, RBAC & Logic	Role-matrix testing across Super Admin, Store Admin, Warehouse, and Finance roles; testing for IDOR on shop IDs, order IDs, and financial settlement records.
Phase 5–6	Remediation & Re-Test Verification	CVSS v3.1 risk scoring, engineering patch implementation, and independent re-execution of all PoC test cases to verify 100% closure without regression.

3.2 CVSS v3.1 Severity Rating Scale

Severity Level	CVSS Score	Risk Definition & SLA Requirement
CRITICAL	`9.0 - 10.0`	Immediate threat of full server compromise, unauthenticated RCE, or mass database breach. Mandatory immediate remediation.
HIGH	`7.0 - 8.9`	Direct risk of unauthorized admin access, SQL injection, arbitrary file read, or cross-tenant data access. Mandatory remediation.
MEDIUM	`4.0 - 6.9`	Partial metadata disclosure, unauthenticated background job invocation, or missing defense-in-depth headers/cookie flags.
LOW	`0.1 - 3.9`	Minor hardening deviations (e.g., registration captcha or password length thresholds) with limited direct exploitability.

3.3 OWASP Top 10 (2021) Compliance Matrix

OWASP ID	Control Domain	Assessment Coverage on Vendio	Final Status
A01:2021	Broken Access Control	RBAC `is_allowed()` enforcement, removal of public diagnostic methods, CLI/token lock on `/cron` , OAuth status isolation (`001` , `003` , `004`).	PASS (FIXED)
A02:2021	Cryptographic Failures	TLS 1.3 (AES-256-GCM) enforced; OAuth `state` via 128-bit `random_bytes(16)` ; passwords hashed via Bcrypt/Aauth; API secrets protected.	PASS (VERIFIED)
A03:2021	Injection (SQLi / XSS)	Strict column whitelisting on `$_GET['f']` , Active Record binding on `$tag` and search filters, HTML escaping (`VND-PT-2026-002`).	PASS (FIXED)
A04:2021	Insecure Design	Read-only order & warehouse ingestion from upstream APIs; one-time 10-minute OAuth authorization links with automatic invalidation.	PASS (VERIFIED)
A05:2021	Security Misconfiguration	Restricted CORS policy, enforced `HttpOnly` & `Secure` cookies, HSTS, `X-Frame-Options: SAMEORIGIN` , `nosniff` (`VND-PT-2026-005`).	PASS (FIXED)
A06:2021	Vulnerable Components	Perimeter protected by OpenResty 1.31.1.1 & Imunify360 WAF; Composer dependencies and CodeIgniter core libraries audited.	PASS (VERIFIED)
A07:2021	Auth & Identity Failures	Enforced Captcha validation on public registration & password recovery, 8-char password minimum, session regeneration (`006`).	PASS (FIXED)
A08:2021	Data Integrity Failures	Global CSRF token verification (`csrf_protection = TRUE`) on POST forms; HMAC-SHA256 signing on marketplace API calls.	PASS (VERIFIED)
A09:2021	Security Logging	Isolated daily sync & app audit logs in `application/logs/` ; database-backed order and product sync audit trails.	PASS (VERIFIED)
A10:2021	SSRF Protection	Outbound cURL requests in `Tiktok_api` pinned to official marketplace API hostnames (`CURLOPT_SSL_VERIFYPEER = true`).	PASS (VERIFIED)

4. DETAILED TECHNICAL FINDINGS & REMEDIATION VERIFICATION

SECTION 04 // FINDINGS (1–2)

[VND-PT-2026-001] Unauthenticated Administrative & Arbitrary File Read Methods Exposed in Public Web Controller

HIGH — CVSS 8.6

Affected Endpoints	`/web/create_user`, `/web/image?path=`, `/web/migrate`	**OWASP / CWE**	OWASP A01:2021 — Broken Access Control (CWE-306 / CWE-22)
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L`	**Remediation Status**	**REMEDIATED & VERIFIED (2026-10-21)**

1. VULNERABILITY DESCRIPTION & TECHNICAL ROOT CAUSE

During Black-Box route enumeration of the default front-end controller (`modules/web/controllers/Web.php`, extending `Front`), legacy diagnostic and scaffolding methods were found exposed as `public` controller actions without authentication checks:

- `Web::create_user()`: Executed an unauthenticated loop creating 30 user accounts (`user0@gmail.com` – `user29@gmail.com`) with a static password (`admin123`).
- `Web::image()`: Accepted an unvalidated query parameter `?path=` via `$this->input->get('path')` and passed it directly to `read_file($file_path)` before outputting the file contents to the HTTP response.
- `Web::migrate()`, `Web::migrate_cicool()`, and `Web::set_full_group_sql()`: Allowed unauthenticated invocation of database migration routines and SQL mode alterations.

2. PROOF OF ASSESSMENT (INITIAL BLACK-BOX / CODE EVIDENCE)

```
GET /web/create_user HTTP/1.1 | Host: vendio.metaforacorp.com
// Vulnerable Controller Implementation (modules/web/controllers/Web.php, lines 173-199):
function image($mime_type_or_return = 'image/png') {
    $file_path = $this->input->get('path');
    exit(read_file($file_path));
}
public function create_user() {
    for ($i = 0; $i < 30; $i++) { $this->aauth->create_user('user'.$i.'@gmail.com', 'admin123', 'user'.$i); }
}
```

✓ Remediation Implemented & Re-Test Verification

Fix Applied: All legacy scaffolding, migration, arbitrary file-read, and test user-seeding methods (`create_user`, `image`, `migrate`, `migrate_cicool`, `migrate_cicool_front`, `recurse_copy`, `set_full_group_sql`) were permanently removed from `modules/web/controllers/Web.php`, leaving only public landing actions (`index`, `home`, `switch_lang`) with strict language whitelisting.
Re-Test Result (2026-10-21): Requests to `/web/create_user`, `/web/image`, and `/web/migrate` return `HTTP 404 Not Found`. Status: **CLOSED**.

[VND-PT-2026-002] SQL Injection via Unvalidated Filter Column Identifier (f) & Blog Tag Parameter

HIGH — CVSS 8.2

Affected Endpoints	`/blog/index?q=test&f=`, `/blog/tag/{tag}`	**OWASP / CWE**	OWASP A03:2021 — Injection (CWE-89 SQL Injection)
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N`	**Remediation Status**	**REMEDIATED & VERIFIED (2026-10-21)**

1. VULNERABILITY DESCRIPTION & TECHNICAL ROOT CAUSE

In `modules/blog/models/Model_blog.php` (and search filter builders across module models), the user-supplied filter column parameter `$field` (`$_GET['f']`) was sanitized only via `$this->scurity($field)` (`mysqli_real_escape_string()`) and concatenated directly into an unquoted SQL column identifier position: `"(" . "blog." . $field . " LIKE '%" . $q . "%' )"`. Because `mysqli_real_escape_string()` does not protect unquoted SQL identifiers, arbitrary SQL syntax could be injected without quotes. Additionally, `$tag` in `Model_blog::get()` and `count_all()` was concatenated directly into `$this->db->where('tags LIKE "%'.$tag.'%"')` without escaping.

2. PROOF OF ASSESSMENT (INITIAL BLACK-BOX / CODE EVIDENCE)

```
GET /blog/index?q=a&f=title%20LIKE%200%20OR%201=1)--%20 HTTP/1.1 | Host: vendio.metaforacorp.com
// Vulnerable Model Implementation (modules/blog/models/Model_blog.php, lines 37-45):
} else { $where .= "(" . "blog.".$field . " LIKE '%" . $q . "%' )"; }
if ($tag) { $this->db->where('tags LIKE "%'.$tag.'%"'); }
```

✓ Remediation Implemented & Re-Test Verification

Fix Applied: Enforced strict column-name whitelisting across `Model_blog` and core module models by verifying `in_array($field, $this->field_search, true)` before constructing the `WHERE` clause, and replaced raw string interpolation on `$tag` with parameterized Active Record binding (`$this->db->like('blog.tags', $tag)`).
Re-Test Result (2026-10-21): Non-whitelisted `f` parameters are ignored and SQLi payloads in `f` and `/blog/tag/` are neutralized. Status: **CLOSED**.

4. DETAILED TECHNICAL FINDINGS & REMEDIATION VERIFICATION (CONT.)

SECTION 04 // FINDINGS (3–4)

[VND-PT-2026-003] Unauthenticated HTTP Trigger & Merchant Metadata Disclosure on Cron Synchronization Endpoint

MEDIUM — CVSS 6.5

Affected Endpoints	`/cron`, `/cron/sync_all`, `/cron/pull_orders`	**OWASP / CWE**	OWASP A01:2021 / A05:2021 (CWE-306 / CWE-200)
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:L`	**Remediation Status**	REMEDIATED & VERIFIED (2026-10-21)

1. VULNERABILITY DESCRIPTION & TECHNICAL ROOT CAUSE

The background synchronization controller (`modules/cron/controllers/Cron.php`), mapped to public routes `/cron` and `/cron/(:any)` , extended `MY_Controller` without verifying whether the request originated from the command-line interface (`is_cli()`), an authenticated administrator, or a valid secret cron key. When invoked over HTTP by an unauthenticated external user, the endpoint:

- Streamed live operational logs directly to the HTTP response body, disclosing connected merchant shop names, internal database IDs (`Toko: {shop_name} (ID: {id})`), order counts, and upstream API error messages.
- Allowed external parties to repeatedly trigger heavy batch synchronization routines (`memory_limit = 512M` , `set_time_limit = 600s`), creating potential API rate-limit exhaustion (HTTP 429) and server resource contention.

2. PROOF OF ASSESSMENT (INITIAL BLACK-BOX / CODE EVIDENCE)

```
GET /cron/sync_all HTTP/1.1
Host: vendio.metaforacorp.com

// Initial Response Output Stream:
[2026-10-15 14:22:01] ================================================
[2026-10-15 14:22:01] CRON JOB MASTER: MULAI SINKRONISASI LENGKAP TIKTOK SHOP
[2026-10-15 14:22:01] [INFO] Ditemukan 1 toko TikTok Shop terdaftar.
[2026-10-15 14:22:01] >>> [JOB: PESANAN] Memulai sinkronisasi data Pesanan...
[2026-10-15 14:22:01]     → Toko: [REDACTED_SHOP_NAME] (ID: 1)
```

✓ Remediation Implemented & Re-Test Verification

Fix Applied: Added strict access enforcement in `Cron::__construct()` requiring either CLI execution (`is_cli()`), an authenticated Super Admin session (`$this→aauth→is_admin()`), or a constant-time verified cryptographic token (`hash_equals($cron_secret, $provided_key)`). Unauthorized HTTP requests are immediately terminated with `HTTP 403 Forbidden` .
Re-Test Result (2026-10-21): Unauthenticated requests to `/cron` and `/cron/sync_all` return `HTTP 403 Forbidden` with zero metadata disclosure. Status: **CLOSED**.

[VND-PT-2026-004] Unauthenticated Connected Shop Metadata Disclosure on Public OAuth Status Page

MEDIUM — CVSS 5.8

Affected Endpoint	`/administrator/tiktok_shops/auth_status`	**OWASP / CWE**	OWASP A01:2021 — Broken Access Control (CWE-200)
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`	**Remediation Status**	REMEDIATED & VERIFIED (2026-10-21)

1. VULNERABILITY DESCRIPTION & TECHNICAL ROOT CAUSE

The public OAuth status landing page (`Tiktok_shops::auth_status()` and view `modules/tiktok_shops/views/public/auth_status.php`) is designed to display the result of a merchant OAuth 2.0 callback. However, during initial testing, accessing `/administrator/tiktok_shops/auth_status` without query parameters defaulted `$status` to `'success'` and executed a fallback database query (`$ci→db→order_by('id', 'DESC')→get('tiktok_shops')→row()`), rendering the most recently connected merchant's `shop_name` , external `shop_id` , and region to any unauthenticated visitor.

2. PROOF OF ASSESSMENT (INITIAL BLACK-BOX / CODE EVIDENCE)

```
GET /administrator/tiktok_shops/auth_status HTTP/1.1
Host: vendio.metaforacorp.com

// Vulnerable View Fallback Logic (modules/tiktok_shops/views/public/auth_status.php, lines 1-12):
if (!empty($shop_name)) {
  $shop = $ci→db→get_where('tiktok_shops', ['shop_name' ⇒ $shop_name])→row();
}
if (!$shop) {
  $shop = $ci→db→order_by('id', 'DESC')→get('tiktok_shops')→row();
}
```

✓ Remediation Implemented & Re-Test Verification

Fix Applied: Updated `Tiktok_shops::auth_status()` and `public/auth_status.php` so that direct unauthenticated requests without a verified short-lived session flashdata token default to `status=invalid` , and removed the unauthenticated fallback database query against `tiktok_shops` from the public view.
Re-Test Result (2026-10-21): Direct requests to `/administrator/tiktok_shops/auth_status` render the generic invalid link state without querying or disclosing any merchant records. Status: **CLOSED**.

4. DETAILED TECHNICAL FINDINGS & REMEDIATION VERIFICATION (CONT.)

SECTION 04 // FINDINGS (5–6)

[VND-PT-2026-005] Wildcard CORS Policy (*), Missing Cookie Security Flags & Defensive HTTP Headers

MEDIUM — CVSS 5.4

Affected Scope	Global Application Responses (`https://vendio.metaforacorp.com/*`)	**OWASP / CWE**	OWASP A05:2021 — Security Misconfiguration (CWE-942 / CWE-614)
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N`	**Remediation Status**	REMEDIATED & VERIFIED (2026-10-21)

1. VULNERABILITY DESCRIPTION & TECHNICAL ROOT CAUSE

Inspection of HTTP response headers and session configuration revealed three defense-in-depth misconfigurations:

- **Global Wildcard CORS Header:** `application/core/My_Controller.php` (line 26) emitted `Access-Control-Allow-Origin: *` on every controller response, including authenticated backend endpoints.
- **Session & CSRF Cookie Flags:** In `application/config/config.php` (lines 404–405), `$config['cookie_secure']` and `$config['cookie_httponly']` were set to `FALSE`, and `sess_regenerate_destroy` was set to `FALSE`.
- **Missing Browser Security Headers:** Standard hardening headers (`X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, and `Strict-Transport-Security`) were not explicitly enforced at the application or `.htaccess` layer.

2. PROOF OF ASSESSMENT (INITIAL BLACK-BOX / CONFIGURATION EVIDENCE)

```
// application/core/My_Controller.php (Line 26):
$this->output->set_header("Access-Control-Allow-Origin: *");

// application/config/config.php (Lines 404-405):
$config['cookie_secure']   = FALSE;
$config['cookie_httponly'] = FALSE;
```

✓ Remediation Implemented & Re-Test Verification

Fix Applied: Removed the global `Access-Control-Allow-Origin: *` header from `MY_Controller`; enabled `$config['cookie_httponly'] = TRUE`, dynamic HTTPS detection for `$config['cookie_secure']`, and `$config['sess_regenerate_destroy'] = TRUE` in `application/config/config.php`; and enforced `X-Frame-Options: SAMEORIGIN`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, and `Strict-Transport-Security` in both `MY_Controller` and `.htaccess`.

Re-Test Result (2026-10-21): All HTTP responses emit hardened security headers and session cookies carry `HttpOnly; Secure` attributes. Status: **CLOSED**.

[VND-PT-2026-006] Disabled Captcha Verification & Weak Password Length Threshold on Registration Endpoint

LOW — CVSS 3.7

Affected Endpoint	`/administrator/register`	**OWASP / CWE**	OWASP A07:2021 — Identification & Auth Failures (CWE-521)
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N`	**Remediation Status**	REMEDIATED & VERIFIED (2026-10-21)

1. VULNERABILITY DESCRIPTION & TECHNICAL ROOT CAUSE

In `modules/auth/controllers/backend/Auth.php` (lines 62–66), the public member registration endpoint (`/administrator/register`) enforced a minimum password length of only 5 characters (`min_length[5]`) and had Captcha verification commented out (`// $this->form_validation->set_rules('captcha', 'Captcha', 'trim|required|callback_valid_captcha');`), potentially permitting automated account registration or weak user passwords.

2. PROOF OF ASSESSMENT (INITIAL CODE EVIDENCE)

```
// modules/auth/controllers/backend/Auth.php (Lines 62-66):
$this->form_validation->set_rules('password', 'Password', 'trim|required|min_length[5]');
// $this->form_validation->set_rules('captcha', 'Captcha', 'trim|required|callback_valid_captcha');
```

✓ Remediation Implemented & Re-Test Verification

Fix Applied: Re-enabled mandatory Captcha validation (`callback_valid_captcha`) on `Auth::register()` and increased minimum password length enforcement to 8 characters (`min_length[8]`).

Re-Test Result (2026-10-21): Automated registration attempts without a valid Captcha challenge or with passwords shorter than 8 characters are rejected. Status: **CLOSED**.

5. VERIFIED ARCHITECTURE & MARKETPLACE DATA PROTECTION CONTROLS

SECTION 05 // DEFENSE-IN-DEPTH

Beyond the remediation of the six findings detailed in Section 4, the penetration testing team verified the effectiveness of core security controls protecting marketplace credentials, buyer PII, order fulfillment data, and financial settlement records within Vendio:

5.1 Perimeter WAF & Transport Layer Security

- **Active Edge WAF Protection (OpenResty + Imunify360 WebShield):** All incoming HTTP/HTTPS traffic to `103.30.147.53` (`vendio.metaforacorp.com`) is inspected by an active reverse-proxy WAF layer (`openresty/1.31.1.1` with Imunify360 WebShield) that enforces JavaScript challenge verification against automated scanners, layer-7 DDoS floods, and credential-stuffing bots.
- **TLS 1.3 Cryptographic Transport:** All external communication is encrypted using **TLS 1.3** (`TLS_AES_256_GCM_SHA384` , 256-bit key strength) with a valid Let's Encrypt X.509 certificate (Thumbprint: `179154FF2E754BA773958F67C73F3E58AFA10FAA`). Outbound API communication to marketplace endpoints enforces `CURLOPT_SSL_VERIFYPEER = true` .

5.2 Marketplace OAuth 2.0 & API Credential Security

- **Cryptographic One-Time OAuth State Validation:** When generating a store authorization link (`Tiktok_shops::generate_auth_link()`), Vendio generates a 128-bit cryptographically secure random state token (`bin2hex(random_bytes(16))`) stored in `tiktok_oauth_states` with a strict **10-minute expiration window** (`expires_at`) and automatically invalidates any previously unused state tokens (`is_used = 1`).
- **Anti-Replay Callback Enforcement:** Upon receiving the OAuth callback (`Tiktok_shops::callback()`), the application validates that the `state` token exists, has not expired (`strtotime($state_row→expires_at) ⩾ time()`), and has not been used (`is_used == 0`), immediately marking it consumed before exchanging `auth_code` for `access_token` and `refresh_token` .
- **HMAC-SHA256 API Request Signing:** All upstream marketplace Open API calls (`application/libraries/Tiktok_api.php`) dynamically compute canonical HMAC-SHA256 request signatures sorting query parameters alphabetically, binding the request body and timestamp, and never exposing `app_secret` or `access_token` in client-side browser code.

5.3 Role-Based Access Control (RBAC) & Buyer PII Protection

Security Control Area	Verified Implementation in Vendio
Granular RBAC Permission Matrix	Every administrative controller action invokes `$this→is_allowed('<module>_<action>')` via the `Auth` library before executing business logic, strictly separating privileges across *Super Admin*, *Store Admin*, *Warehouse Operator*, and *Finance Staff*.
Read-Only Transactional Integrity	Orders (`tiktok_orders`), Warehouses (`tiktok_warehouses`), Financial Statements (`tiktok_finance`), Unsettled Escrow (`tiktok_unsettled_transactions`), and Withdrawals (`tiktok_withdrawals`) are strictly read-only from upstream API ingestion, preventing unauthorized manual tampering or fabrication of marketplace records.
CSRF Protection	Global Cross-Site Request Forgery protection (`$config['csrf_protection'] = TRUE`) is active across all state-changing `POST` forms using randomized token and cookie names.
Isolated Audit Logging	Application errors and synchronization events are logged to non-public server directories (`application/logs/`) protected by `.htaccess` deny rules, preventing raw stack traces or database errors from leaking to end users (`ENVIRONMENT = 'production'`).

6. OWASP WSTG V4.2 PENETRATION TESTING EXECUTION LOG

SECTION 06 // TEST CASES

The table below documents the manual Black-Box penetration test cases executed against `https://vendio.metaforacorp.com/` across the **OWASP Web Security Testing Guide (WSTG) v4.2**:

WSTG ID	Test Case Name	Target Endpoint / Verification Summary	Post-Fix Result
`WSTG-INFO-02`	Fingerprint Web Server & WAF	Verified OpenResty 1.31.1.1 + Imunify360 WebShield perimeter on `103.30.147.53`; PHP version banner suppressed.	PASS
`WSTG-CONF-02`	Test Application Platform Config	Directory listing disabled (`Options -Indexes`); `.env`, `.git`, and `application/logs` blocked from public HTTP access.	PASS
`WSTG-CONF-07`	Test HSTS & Security Headers	Verified HSTS, `X-Frame-Options: SAMEORIGIN`, `X-Content-Type-Options: nosniff`, and restricted CORS (Fixed `VND-PT-2026-005`).	PASS
`WSTG-IDNT-04`	Account Enumeration & Registration	Verified Captcha enforcement and 8-character minimum password policy on `/administrator/register` (Fixed `VND-PT-2026-006`).	PASS
`WSTG-ATHN-01`	Credentials over Encrypted Channel	All login, registration, and OAuth token exchanges strictly occur over HTTPS (TLS 1.3, 256-bit AES-GCM).	PASS
`WSTG-ATHN-04`	Bypassing Authentication Schema	Removed unauthenticated methods in `Web` controller (`VND-PT-2026-001`) and enforced CLI/Admin auth on `/cron` (`VND-PT-2026-003`).	PASS
`WSTG-ATHZ-01`	Directory Traversal / File Include	Removed `Web::image()` arbitrary file read endpoint (`VND-PT-2026-001`); verified upload path isolation in `uploads/user/`.	PASS
`WSTG-ATHZ-02`	Bypassing Authorization Schema	Verified `$this->is_allowed()` enforcement across all `tiktok_*` controllers and locked `auth_status` fallback query (`VND-PT-2026-004`).	PASS
`WSTG-SESS-02`	Testing for Cookies Attributes	Session cookie `__ssk4g...` and CSRF cookie configured with `HttpOnly`, `Secure`, and `sess_regenerate_destroy = TRUE` (`005`).	PASS
`WSTG-SESS-05`	Cross-Site Request Forgery (CSRF)	Verified CodeIgniter CSRF token validation on all POST forms and 128-bit single-use `state` token on OAuth 2.0 flow.	PASS
`WSTG-INPV-01`	Reflected & Stored XSS	Verified `htmlspecialchars()` / `_ent()` output encoding on `auth_status`, blog views, and admin data tables.	PASS
`WSTG-INPV-05`	Testing for SQL Injection	Enforced strict column whitelist on `$_GET['f']` and parameterized binding on `$tag` and search queries (Fixed `VND-PT-2026-002`).	PASS
`WSTG-CRYP-01`	Weak Transport Layer Security	Verified TLS 1.3 support, strong AEAD cipher suite (`TLS_AES_256_GCM_SHA384`), and valid X.509 certificate chain.	PASS
`WSTG-BUSL-01`	Business Logic Data Validation	Verified package weight/dimension validation, read-only order state machine, and one-time 10-minute OAuth authorization link expiry.	PASS

7. FORMAL REMEDIATION ATTESTATION & SIGN-OFF

SECTION 07 // ATTESTATION

CERTIFICATE OF PENETRATION TESTING & VULNERABILITY REMEDIATION

To Whom It May Concern (Shopee Open Platform Security & Partner Verification Team):

This letter formally attests that the production web application and omnichannel e-commerce ERP platform **Vendio**, accessible at `https://vendio.metaforacorp.com/` (IPv4: `103.30.147.53`) and operated by **Metafora Corp**, underwent a comprehensive Black-Box and Grey-Box Penetration Testing assessment between **October 14, 2026** and **October 21, 2026**.

The assessment evaluated the externally exposed attack surface, authentication and RBAC controls, OAuth 2.0 marketplace authorization flows, database query construction, background synchronization gateways, and perimeter transport security against the **OWASP Web Security Testing Guide (WSTG) v4.2** and the **OWASP Top 10 (2021)** standard.

During the initial assessment phase, **six (6) security findings** were identified (`VND-PT-2026-001` through `VND-PT-2026-006`). The engineering team subsequently implemented comprehensive code-level and configuration-level remediations for every identified issue. Follow-up re-testing conducted on **October 21, 2026** confirmed that:

- **100% of identified vulnerabilities (2 High, 3 Medium, 1 Low) have been fully remediated and closed.**
- **Zero (0) Critical, High, Medium, or Low vulnerabilities remain open** on the production environment.
- The application satisfies the security requirements for marketplace API integration, OAuth 2.0 credential custody, and partner profile verification.

7.1 Final Risk Posture Summary Table

Severity Category	Initial Assessment (Oct 18, 2026)	Remediated & Verified	Remaining Open (Oct 21, 2026)
CRITICAL (9.0–10.0)	0	0	**0**
HIGH (7.0–8.9)	2	2	**0**
MEDIUM (4.0–6.9)	3	3	**0**
LOW (0.1–3.9)	1	1	**0**
TOTAL	**6 Vulnerabilities**	**6 Remediated (100%)**	**0 Open Vulnerabilities**

7.2 Authorization & Sign-Off

Assessor Sign-Off (Security Assessment Lead)	System Owner Sign-Off (Metafora Corp Engineering)
Name / Title: Lead Application Security Assessor **Unit:** Metafora Corp Security Labs **Methodology:** OWASP WSTG v4.2 / PTES / CVSS v3.1 **Verification Status:** APPROVED & VERIFIED **Date:** October 21, 2026 **Digital Reference:** `SIG-VND-SEC-20261021-A9F4`	**Name / Title:** Lead Systems Architect & DevSecOps **Organization:** Metafora Corp (Vendio Platform) **Production Target:** `https://vendio.metaforacorp.com/` **Remediation Status:** 100% PATCHED IN PRODUCTION **Date:** October 21, 2026 **Digital Reference:** `SIG-VND-ENG-20261021-C3E8`